

Stoquify Agent Runtime Phase 2A Credential Rotation Evidence Capture Execution Report

Date: 2026-07-25

Scope: Production-authority credential evidence intake

Result: Repository implementation complete; external evidence absent; activation blocked

Executive Result

Stoquify now has a fail-closed, value-free ingestion path for real credential classification, rotation, revocation, workload restart, new-version verification, and old-version rejection evidence.

The collector does not perform a rotation and cannot activate an agent. It authenticates to an independent security authority, proves invalid authentication is rejected, requires all 15 declared credential classes exactly once, binds the attestation to the same inactive certified release, and updates only the credential register and its operational hash/reference binding.

The real preflight correctly failed on `CREDENTIAL_EVIDENCE_URL_MISSING`. No authority endpoint or managed bearer secret exists in the current workspace, so no capture artifact, approval, identity, rotation event, or register completion was fabricated.

Implemented

- `scripts/agent-credential-rotation-evidence-capture.js`
- `scripts/__tests__/agent-credential-rotation-evidence-capture.test.js`
- Authority and frozen-release validation in `scripts/agent-credential-rotation-gate.js`
- Credential evidence binding in `scripts/agent-operational-release-gate.js`
- Phase 2A static-ratchet coverage
- Report, gate, and guarded-apply package commands
- Managed configuration contract in `.env.example`
- Value-free authority and release-binding fields in the credential register
- Capture hash and attestation fields in the operational register
- `docs/agents-runtime/STOQUIFY_AGENT_CREDENTIAL_ROTATION_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

Capture Controls

The collector enforces:

- query-free HTTPS outside local development;
- bearer secrets of at least 32 characters;
- bounded 5-to-60-second request timeout;
- 250 KB maximum response size;
- invalid-authentication `401` proof;
- authenticated `200` evidence response;
- exact environment, register ID, and incident match;
- attestation age no greater than 24 hours;

- real, non-synthetic security identities;
- exact coverage of all configured credential classes;
- value-free allowlisted fields only;
- release/package/commit/artifact/deployment identity equality;
- inactive `PILOT_CERTIFIED` state;
- ordered rotation, restart, verification, revocation, rejection, and review timestamps;
- entry owner and approval equality with the register authority;
- immutable completed evidence.

Forbidden keys include credential, password, token, authorization, raw environment, database URL, connection string, access token, refresh token, and private-key value fields.

Guarded Apply

A ready capture can update:

- credential register status, owner, approval, authority, release binding, dispositions, and value-free evidence;
- operational `credentialRotation.registerSha256` ;
- operational `credentialRotation.securityApprovalReference` ;
- operational `credentialRotation.evidenceSha256` ;
- operational `credentialRotation.attestationReference` .

It cannot update:

- release or CI identity;
- governance, product/security approvals, or operational owners;
- scheduler or alerting evidence;
- operational declared status;
- package state;
- activation fields.

The register hash is computed from the exact JSON bytes written to disk. A partially completed two-file write remains fail-closed because the operational register cannot pass without the matching credential-register hash.

Gate Hardening

The credential gate now additionally requires:

- value-free authority source, attestation, digest, timestamp, capture hash, and invalid-auth reference;
- authority evidence no older than 24 hours;
- frozen environment, package, release, commit, artifact, and deployment binding;
- inactive `PILOT_CERTIFIED` package state;
- owner and approval consistency for every completed credential class;
- review no later than authority attestation;
- optional exact comparison to the operational frozen release.

The current credential register is correctly `BLOCKED` :

```
credential classes: 15
credential gate blockers: 31
secret values printed: false
```

The operational gate additionally requires the credential capture hash and attestation reference. Its current state is:

```
status: BLOCKED
blockers: 146
activationAuthorized: false
```

Blocker categories:

Category	Count
Release	14
CI	15
Governance	12
Approvals	14
Owners	36
Scheduler	33
Alerting	17
Credential rotation	5
Total	146

Verification

Verification	Result
Credential collector tests	9 passed
Credential gate tests	8 passed
Operational gate tests	21 passed
All focused evidence suites	7 suites, 73 tests passed
Focused <code>--detectOpenHandles</code>	7 suites, 73 tests passed cleanly; no open handle identified
Complete Jest	473 suites and 2,852 tests passed; 3 suites and 15 tests skipped
Complete Jest process	Intermittent forced-worker-exit warning after all tests passed
TypeScript	Passed
Agent Runtime gates	Passed
Phase 2A static ratchet	Passed

Verification	Result
Service-boundary gate	0 active violations
Raw-error boundary gate	0 active unsafe findings
Credential gate	BLOCKED, 31 blockers
Operational gate	BLOCKED, 146 blockers, activation false
Real collector preflight	Failed closed on CREDENTIAL_EVIDENCE_URL_MISSING
Secret values printed	No

The repository-level Jest worker warning remains a separate diagnostic follow-up. The seven evidence suites pass cleanly under `--detectOpenHandles`, so this report does not claim the broader warning is resolved.

External Work Still Required

Completion requires:

- an independent security authority endpoint;
- a managed bearer secret;
- real security owner identity and approval;
- classification of all 15 credential classes;
- managed secret-version references for credentials that were present;
- real rotation and activation timestamps;
- dependent workload restart evidence;
- new-version success evidence;
- old-version revocation and rejection evidence;
- a fresh authority attestation;
- prior CI/release capture so the credential evidence can bind to an immutable inactive deployment.

After the frozen release exists, run:

```
npm run agent:credential-rotation:evidence:apply
npm run agent:credential-rotation:gate
npm run agent:operational-release:gate
```

Passing those commands would make the package eligible only for independent review. Internal activation remains a later protected ceremony, and Phase 3 remains unauthorized.